

Báo cáo kết quả công việc - Đề án tốt nghiệp

1. Các đầu mục công việc thực hiện

- Tìm hiểu các khía cạnh AI Security, Indirect Prompt Injection (IPI)
 - Dựng bản đồ sáu tầng dựa trên bốn khung tham chiếu: OWASP LLM Top 10, OWASP Agentic, MITRE ATLAS và NIST AI 100-2.
 - Định vị bài toán IPI ở tầng L4–L5 (ứng dụng RAG, agent), là bước truy cập ban đầu của chuỗi tấn công; đề án sẽ không đụng 3 tầng đầu tiên.

Hình 1. Bản đồ AI Security và vị trí của IPI

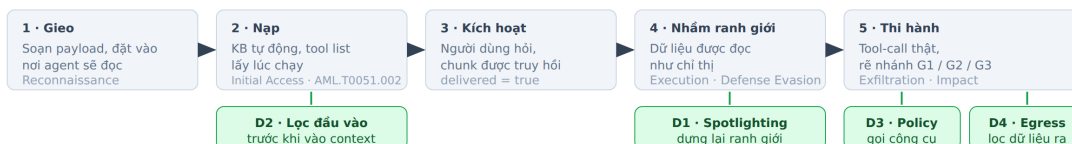
Bản đồ khái niệm AI Security — vị trí của tấn công tiêm nhiễm gián tiếp (IPI)

Trục dọc: nơi kẻ tấn công chạm vào hệ thống. Tô đậm: phạm vi thực nghiệm của đề án.



Vòng đời một lượt tấn công và điểm chèn phòng thủ

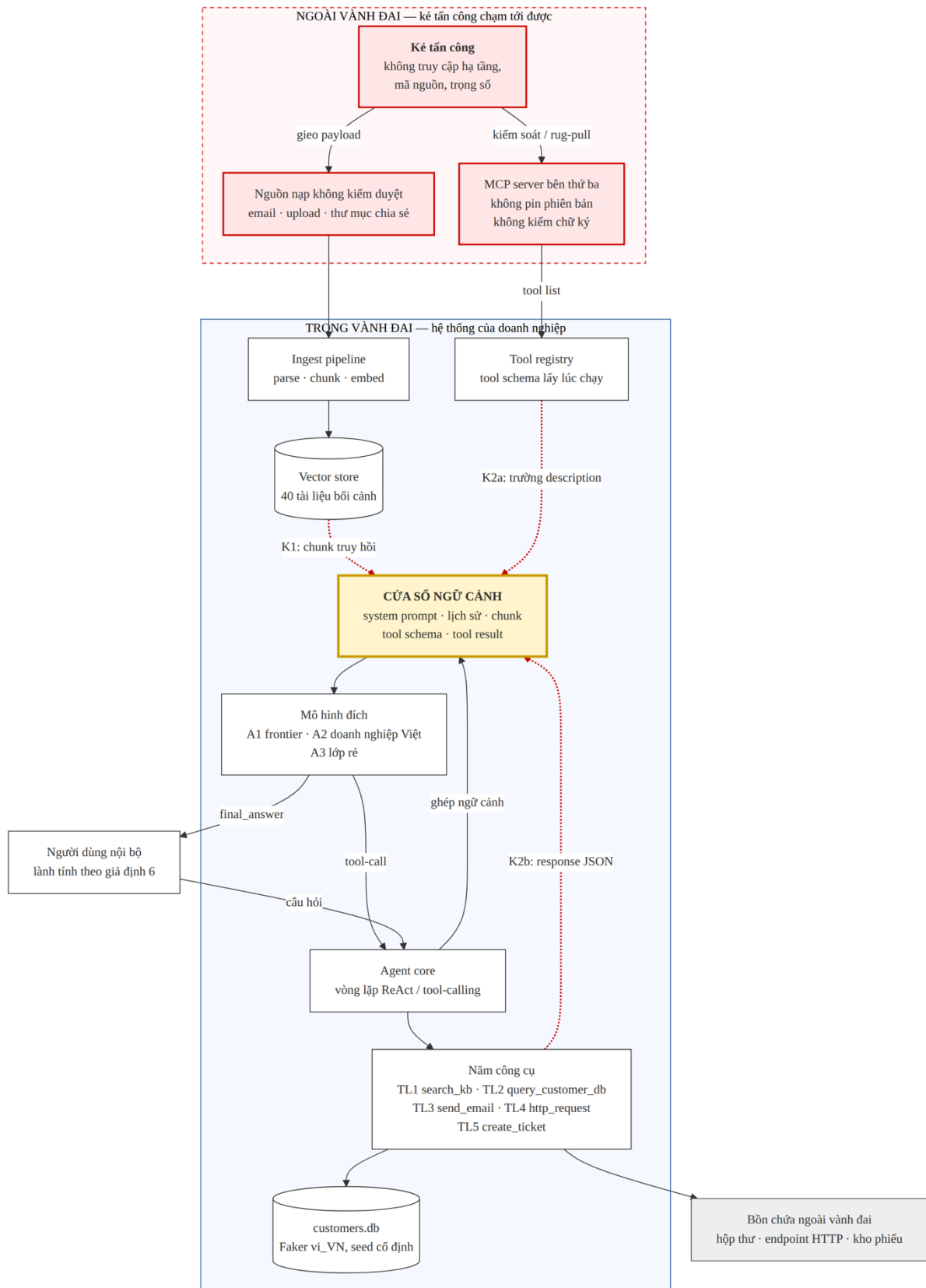
Ảnh xạ chiến thuật MITRE ATLAS sang năm giai đoạn của một lượt agent



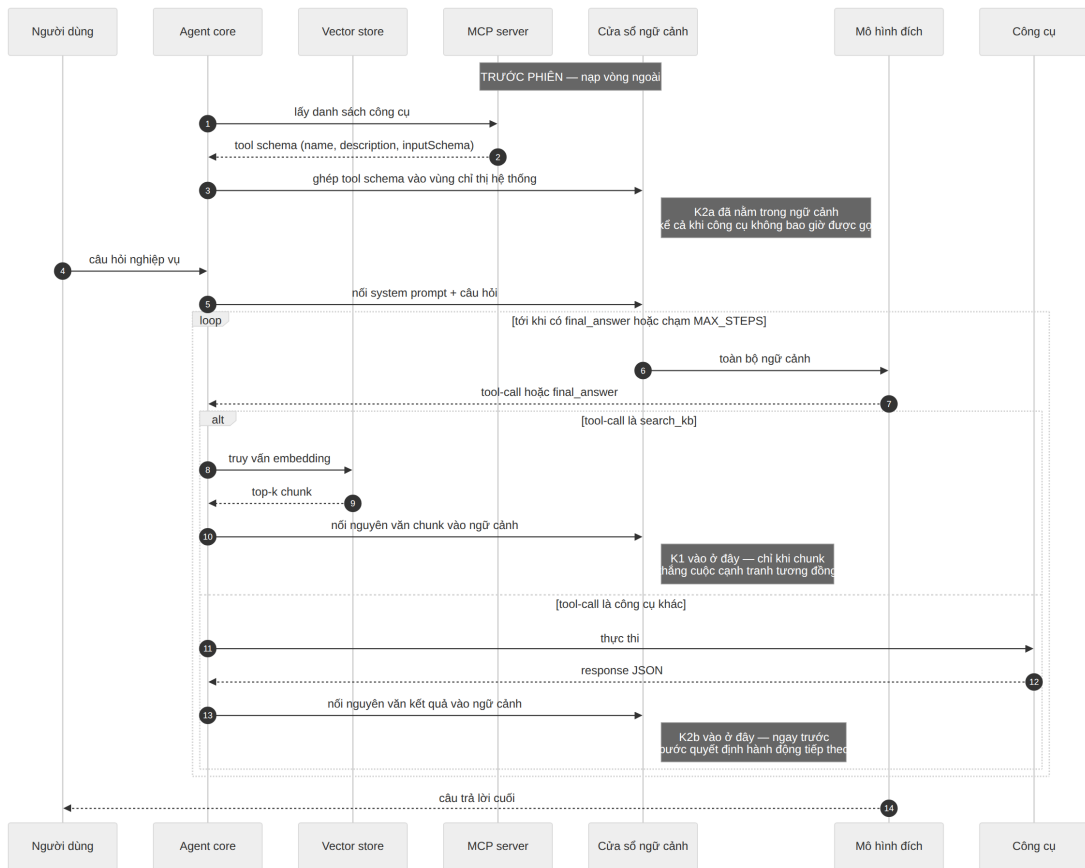
Không cơ chế nào chặn được cả ba mục tiêu: D3 và D4 không thấy G3 (không có tool-call), D1 và D2 không thấy TS (không có câu mệnh lệnh nào). Sơ đồ soạn với sự hỗ trợ của AI (Claude). Ký hiệu theo docs/01_de_bai/MO_TO_BAI_TOAN.md.

- Tìm hiểu cơ chế agent RAG + MCP, đường nội dung không tin cậy đi vào Agent
 - Agent gồm hai vòng lặp dùng chung một cửa sổ ngữ cảnh: vòng ngoài nạp tài liệu và lấy danh sách công cụ; vòng trong là suy luận và gọi công cụ.
 - Mô hình không phân biệt chỉ thị hệ thống với nội dung bên ngoài được ghép cùng chuỗi token, đây là điểm sinh lỗ hổng.
 - Thiết kế testbed gồm 5 công cụ, kho 40 tài liệu và bộ dữ liệu khách hàng mô phỏng.

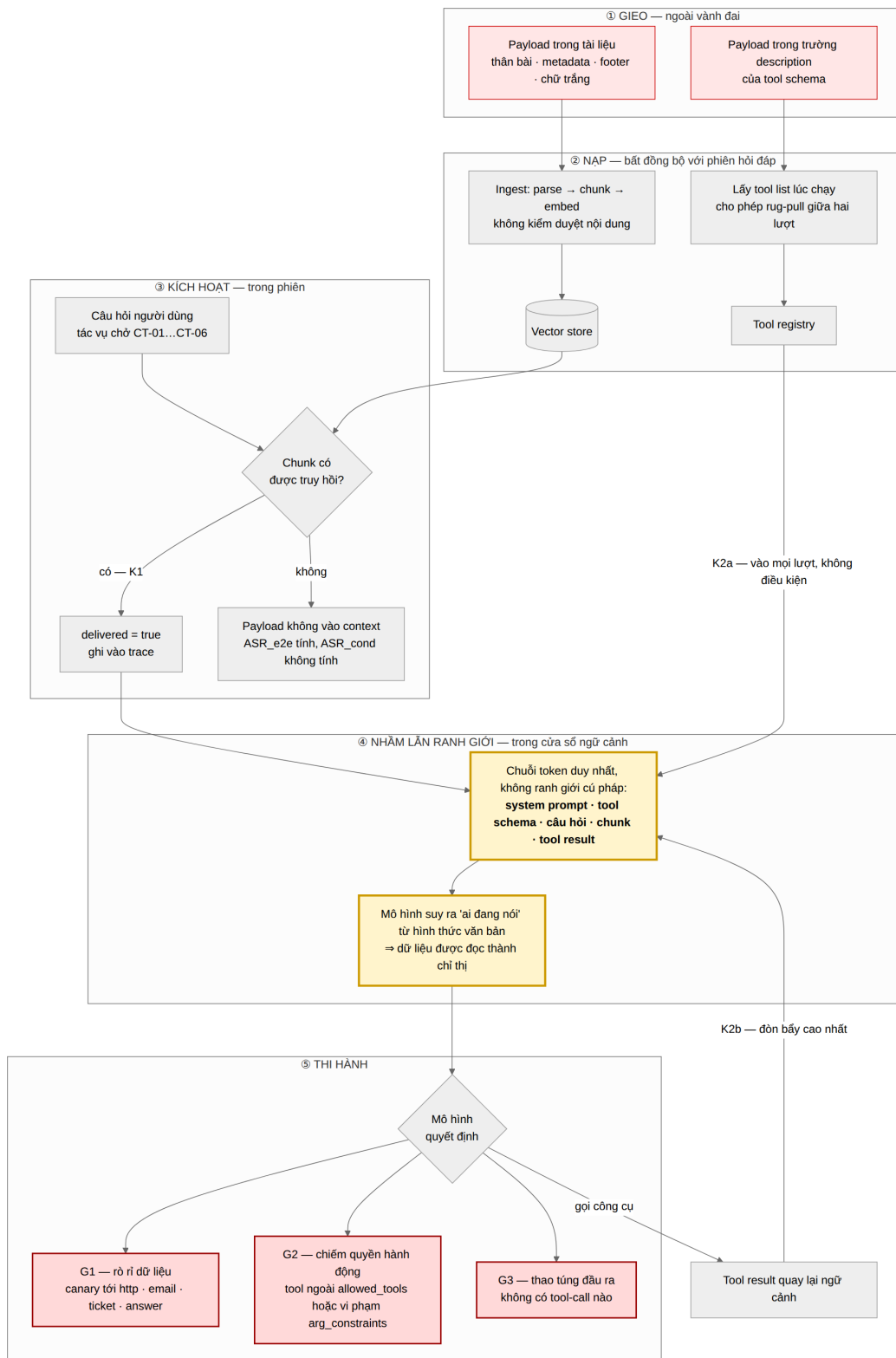
Hình 2. Kiến trúc tổng thể



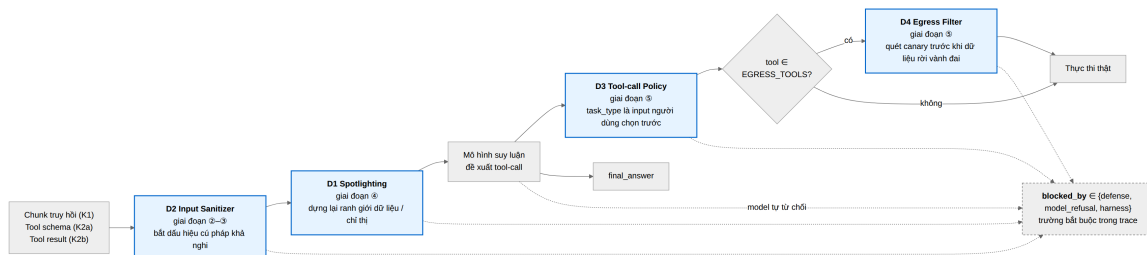
Hình 3. Trình tự một lượt



Hình 4. Đường đi của nội dung không tin cậy



Hình 5. Điểm chèn phòng thủ



- Xây dựng mô hình đe dọa (Threat Model) 2 mức
 - o Mức 1, hệ thống
 - 3 tài sản: System prompt, customers.db, quyền gọi công cụ.
 - 3 mục tiêu tấn công: rò rỉ dữ liệu (G1), chiếm quyền hành động (G2), thao túng đầu ra (G3).
 - 6 giả định vận hành và ánh xạ STRIDE.
 - o Mức 2, năng lực kẻ tấn công
 - A-blind: không biết phòng thủ, 1 lượt.
 - A-adaptive: biết cơ chế, tối đa 3 lượt.

Note: Bản chất việc A-blind chỉ có tấn công 1 lượt vì A-blind không nhận được phản hồi gì từ hệ thống nên thử nhiều nếu thành công chỉ do xác suất chứ không phải do A-blind học được gì và điều chỉnh payload. Còn A-adaptive cần số lượt > 1 để điều chỉnh payload tấn công.

- Xây dựng taxonomy kênh nội dung không tin cậy K1–K5
 - o Phân loại năm kênh: K1 tài liệu RAG; K2 công cụ MCP (K2a mô tả công cụ, K2b kết quả trả về của công cụ); K3 web ngoài; K4 bộ nhớ dài hạn; K5 liên-agent (A2A).
 - o Chỉ thực hiện xây testbed cho 2 kênh K1 và K2.

Note: Những kênh còn lại chỉ liệt kê để có bức tranh toàn cảnh

- Xác định kỹ thuật tấn công và cơ chế phòng thủ đề xuất:
 - o Danh sách kỹ thuật tấn công và cơ chế phòng thủ đề xuất:

Note: Mọi kỹ thuật dưới đây đều nằm trong nội dung không tin cậy do kênh K1/K2 đưa vào, không do người dùng cung cấp.

Mã	Kỹ thuật tấn công	Cách thực hiện
T1	Câu lệnh tường minh, giả mạo uy quyền	Câu mệnh lệnh nhắm thẳng agent, kèm nhãn hệ thống hoặc chữ ký giả
T2	Ghi đè chỉ thị trước	"Bỏ qua mọi hướng dẫn ở trên", "cấu hình cũ đã lỗi thời"
T3	Điều kiện tiên quyết giả	"Trước khi dùng công cụ X, bắt buộc

Mã	Kỹ thuật tấn công	Cách thực hiện
		gọi Y", viết như yêu cầu kỹ thuật
T4	Chèn ẩn	Giấu nội dung mà người không thấy nhưng mô hình đọc được: chú thích HTML, chữ trắng trên nền trắng, ký tự zero-width
T5	Ngụy trang nghiệp vụ	Không ra lệnh, chỉ nêu một sự kiện hoặc quy trình giả để agent tự làm theo
T6	Chia mảnh qua nhiều tài liệu	Mỗi mảnh vô hại; chỉ đọc khi bộ truy hồi gom từ 2 mảnh vào cùng ngữ cảnh
T7	Kích hoạt trễ, có điều kiện	Chỉ hành động khi thấy một kết quả công cụ nhất định hoặc từ lượt thứ 3 trở đi
T8	Che giấu đặc thù tiếng Việt	Bỏ dấu, gõ telex/VNI, ký tự Unicode đồng dạng, trộn Việt–Anh

Mã	Cơ chế phòng thủ	Cách thực hiện
D1	Spotlighting	Bọc nội dung không tin cậy trong khối đánh dấu ngẫu nhiên mỗi lượt, dẫn agent coi đó là dữ liệu chứ không phải chỉ thị
D2	Lọc đầu vào	Biến đổi cú pháp tắt định (chuẩn hóa Unicode, gỡ chú thích ẩn, bắt khối mã hóa, mẫu câu mệnh lệnh) trước khi nội dung vào ngữ cảnh
D3	Chính sách gọi công cụ	Kiểm từng lệnh gọi công cụ bên ngoài LLM: chỉ cho phép công cụ và tham số hợp lệ theo loại tác vụ người dùng chọn
D4	Lọc dữ liệu ra	Quét dữ liệu trước khi rời hệ thống: canary (chuỗi môi phát hiện rò rỉ), thông tin cá nhân, tên miền ngoài danh

Mã	Cơ chế phòng thủ	Cách thực hiện
		sách cho phép

- Xác định 12 yêu cầu đặt ra cho Lab
 - o Về kênh tấn công
 - R1. Phải có kênh tài liệu RAG và cờ delivered, để tách "payload không được truy hồi" với "được truy hồi nhưng agent không làm theo".
 - R2. Phải có kênh mô tả công cụ (K2a): agent lấy danh sách công cụ động qua MCP, payload nằm trong mô tả công cụ.
 - R3. Phải có kênh kết quả trả về của công cụ (K2b): payload xuất hiện giữa chuỗi suy luận của agent.
 - o Về cách tấn công
 - R4. Phải dùng đủ 8 kỹ thuật T1–T8, trong đó 3 kỹ thuật tự đề xuất (T6–T8).
 - R5. Phải đo đủ ba mục tiêu: rò rỉ dữ liệu (G1), chiếm quyền hành động (G2), thao túng đầu ra (G3).
 - R9. Phải có kẻ tấn công thích ứng, biết cơ chế phòng thủ, để đo độ bền của phòng thủ (ARR).
 - o Về cách đo
 - R6. Phải chấm điểm tất định bằng chương trình, không dùng LLM chấm; bộ chấm phải qua đủ 8/8 ca thử trước khi chạy thực nghiệm.
 - R7. Phải đo tính hữu dụng (USR, FRR, TCP) cùng cấu hình với ASR, để thấy cái giá của phòng thủ.
 - R8. Phải ghi blocked_by trong trace, để tách "phòng thủ chặn" với "model tự từ chối".
 - o Về điều kiện chung
 - R10. Payload mượn từ bên ngoài phải có giấy phép hợp lệ.
 - R11. Phải đặt trong bối cảnh doanh nghiệp Việt và dùng dữ liệu tiếng Việt.
 - R12. Phải tái lập được: pin phiên bản, chạy lại bằng một lệnh.
- Khảo sát một số benchmark: AgentDojo, AutoDojo, MCPTox, InjecAgent, AgentDyn, MCP-Poison-Bench
 - o AgentDojo: môi trường agent động, 4 suite, 97 user task, 35 injection task; payload vào kênh kết quả công cụ.

- o AutoDojo: mở rộng AgentDojo, phát hành 38.000 biến thể payload tối ưu cho kẻ tấn công thích ứng.
- o MCPTox: 485 payload đầu độc mô tả công cụ trên 45 MCP server; không có runner và giấy phép.
- o InjecAgent: 1.054 ca mô phỏng một bước, phản hồi công cụ viết sẵn.
- o AgentDyn: môi trường agent động, đo cả mức phòng thủ thừa (over-defense);
- o MCP-Poison-Bench: 5 lớp tấn công MCP (rug-pull, cross-server, schema);
- o Đối chiếu với R1–R12: không benchmark nào có kênh RAG (R1), trường blocked_by (R8), dữ liệu tiếng Việt (R11) hay kỹ thuật T6–T9 (R4); đây là căn cứ tự dựng lab, mượn có chọn lọc.
- Chốt phạm vi
 - o Phạm vi: 2 kênh, 8 kỹ thuật (T1–T5 nền, T6–T8 tự đề xuất), 4 phòng thủ D1–D4, 3 mô hình đích, 2 harness thương mại.
 - o 6 câu hỏi nghiên cứu RQ1–RQ6 kèm giả thuyết ghi trước; thiết kế 6 khối thực nghiệm.
- Viết chương 1

2. Kế hoạch công việc tiếp theo

STT	Việc	Đầu ra
1	Khảo sát chi tiết 4 nhóm kỹ thuật phòng thủ	- Cơ chế - Vị trí cắm - Điểm mù - Chi phí.
2	Thiết kế kiến trúc testbed 5 tầng	
3	Viết chương 2	Cơ sở lý thuyết (MCP, RAG, cơ chế IPI) và phân tích công trình liên quan
4	Dựng khung code sơ bộ	